

차세대 AI 통합 보안 관제 플랫폼 (AI-SOC Platform) 상세 설계 백과사전

본 문서는 기존 Jira 기반의 수동적인 보안 관제(SOC) 티켓팅 시스템을 완벽히 대체하고, 이기종 SIEM 로그의 무손실 수집부터 AI 기반 초동 분석, 그리고 고객사 알림까지의 전 과정을 자동화하는 ****자체 구축형 통합 보안 플랫폼****의 총체적인 설계도이자 백과사전입니다.

제1장. 시스템 아키텍처 및 인프라 설계

플랫폼은 클라우드 네이티브 환경에 최적화되어 있으며, 프론트엔드의 빠른 배포와 백엔드의 고성능 비동기 처리를 위해 하이브리드 아키텍처를 채택합니다.

1.1 인프라 배포 모델 (Vercel + Supabase + Custom Backend)

개발 생산성(Vibe Coding)을 극대화하면서도 대규모 이벤트 처리의 한계를 극복하기 위해 다음과 같이 역할을 분리합니다.

- **프론트엔드 (Vercel 기반 Next.js):**
 - 관제 대시보드 UI를 배포합니다. Vercel의 CDN과 Serverless 기능을 통해 고객사 및 내부 분석가에게 지연 없는 웹 환경을 제공합니다.
- **데이터베이스 및 인증 (Supabase):**
 - **장점:** PostgreSQL 기반의 DBaaS로, 복잡한 인프라 구축 없이 인증과 API를 즉시 사용할 수 있습니다. 특히 ****RLS(Row-Level Security)****를 통해 "고객사 A는 자신의 티켓만, 분석가는 전체 티켓을 볼 수 있는" 강력한 멀티테넌시(데이터 격리)를 DB 엔진 단에서 보장합니다. **JSONB** 데이터 타입을 통해 SIEM 로그의 스키마리스(Schema-less) 저장에도 완벽히 부합합니다.
 - **단점 및 한계:** Supabase 자체만으로는 대규모 백그라운드 큐잉(Queueing)이나 Splunk API 역조회와 같은 장시간 비동기 워커 처리에 한계가 있습니다.
- **커스텀 비동기 백엔드 (FastAPI + RabbitMQ + Celery):**
 - Supabase의 단점을 보완하기 위해, SIEM 웹훅 수신과 무거운 연산(AI 분석, API 콜백)을 담당하는 별도의 워커 서버를 구축합니다.

1.2 전체 시스템 구성도 (Logical Architecture)

-- (1. Webhook) -->

| (2. Raw JSON)

| (3. Consume)

<--- (API) --->

[OpenAI / LLM] <--- (API) ---> | (4. Process, Parse, Map)

| (5. Real-time sync)

[Analyst/Client] <--- (Web) ---> [Next.js Frontend (Vercel)]

제2장. 무결성 기반 **SIEM** 로그 수집 파이프라인 (Zero-Data-Loss)

하루 500건 이상의 경보(경보 1건당 수십~수백 개의 원본 이벤트 포함 가능)가 폭주하는 상황에서 단 하나의 이벤트 누락이나 중복도 허용하지 않는 수집 메커니즘입니다.

2.1 Splunk 연동 시나리오 (콜백 / Pull 패턴)

Splunk의 기본 웹훅은 다수의 이벤트가 발생해도 검색 결과의 '첫 번째 행(First Row)'만 전송하는 치명적인 한계가 있습니다. 이를 해결하기 위해 3단계 수집 프로세스를 적용합니다.

1. 초기 웹훅 수신 (**Fire-and-Forget**): Splunk가 경보 트리거 시 메타데이터(Search ID인 `sid`와 `results_link`)만 플랫폼(FastAPI)으로 발송합니다. 서버는 이를 즉시 RabbitMQ에 적재하고 Splunk에 200 OK를 응답합니다.
2. 비동기 데이터 역조회 (**Pull**): 백그라운드의 Celery 워커가 RabbitMQ에서 `sid`를 꺼낸 뒤, Splunk REST API(`/services/search/jobs/{sid}/results`)를 호출하여 누락된 전체 원본 로그를 끌어옵니다.
3. 데이터 매핑 및 적재: 수집된 전체 로그를 JSONB 형태로 Supabase에 저장합니다.

2.2 리스크 방어 로직 (유실 및 중복 방지)

- 로그 유실 방지:
 - **Splunk Job** 만료 대비: 웹훅 수신 즉시 최우선 순위로 역조회(Pull) 큐에 작업을 할당하여 Splunk 서버에서 데이터가 증발하기 전에 추출합니다.
 - 메시지 큐(RabbitMQ) 영구 보장: 큐 서버 장애 시에도 데이터가 보존되도록 디스크 저장(Persistence) 설정을 강제하고, 처리 실패 시 Dead Letter Queue(DLQ)로 이관하여 관리자가 수동 재처리할 수 있게 합니다.
- 중복 적재 방지 (**Idempotency**):
 - Splunk가 네트워크 지연으로 동일한 웹훅을 재전송할 경우에 대비해, 수신된 ****sid**를 데이터베이스의 고유 식별자(Unique Key)**로 설정합니다.
 - DB 삽입(Insert) 전 `sid` 존재 여부를 검사하여, 이미 존재할 경우 무시하거나 카운트만 올리는 Upsert 처리를 수행합니다.

제3장. 스키마리스(**Schema-less**) 동적 필드 매핑 및

워크플로우

고객사마다, 장비마다 (Sentinel, Logpresso, Splunk 등) 제각각인 로그 포맷을 코드 수정 없이 UI에서 맞추는 엔진입니다.

3.1 동적 매핑 엔진 (JSONPath 활용)

- Supabase의 tickets 테이블에는 공통 필드(id, tenant_id, status, severity)만 생성하고, 파싱된 핵심 필드는 별도 컬럼 없이 JSONB 컬럼 하나(parsed_fields)에 저장합니다.
- 관리자 UI 설정: 관리자는 화면에서 좌측의 'SIEM 원본 JSON 트리'의 result.src_ip 노드를 드래그하여, 우측의 우리 시스템 표준 필드인 source_ip에 드롭합니다. 시스템은 이를 JSONPath 규칙(\$.result.src_ip)으로 저장하여 이후 수신되는 모든 해당 고객사의 로그에 자동 적용합니다.

3.2 워크플로우 및 상태 머신 (State Machine)

NIST 800-61 사고 대응 프레임워크를 기반으로 엄격한 상태 전이(State Transition) 규칙을 적용합니다.

- 상태 흐름: New(신규) → Analyzing(분석 중) → Escalated(고객 대기) → Resolved(조치 완료) → Closed(종료)
- 자동화 트리거: 상태가 Resolved로 변경될 때 분석가가 '근본 원인(Root Cause)' 필드를 채우지 않으면 전이를 차단(Guard)합니다.

제4장. 지능형 AI 초동 분석 코어 (AI Copilot)

티켓이 생성되어 분석가가 화면을 보기 전, AI가 1차적인 수사 보고서를 이미 완성해 둡니다.

- **RAG (검색 증강 생성)** 기반 과거 이력 참조: 새로운 IP에서 공격이 발생하면, 벡터 DB(Supabase pgvector)를 검색하여 "이 IP는 한 달 전 고객사 B에서도 탐지되었으나 사내 취약점 스캐너로 확인되어 오탐(False Positive) 처리됨"이라는 컨텍스트를 가져옵니다.
- 위협 인텔리전스(TI) 연동: 로그 내의 IP, 도메인, 해시값을 추출해 VirusTotal이나 AbuseIPDB 등의 API를 찔러 악성 스코어를 수집합니다.
- **LLM 추론**: 수집된 원본 로그 + TI 정보 + 과거 이력을 종합하여 LLM(GPT-4o 등)에게 전달, "공격 유형, 성공 여부, 추천 조치 방안"이 포함된 요약 브리핑을 작성하게 합니다.

제5장. 관제 분석가 최적화 UI/UX (3-Pane 대시보드)

장시간 모니터링하는 분석가의 인지 부하를 줄이기 위해 React와 Tailwind CSS를 활용한 반응형 3단 분할(3-Pane) 레이아웃을 제공합니다.¹

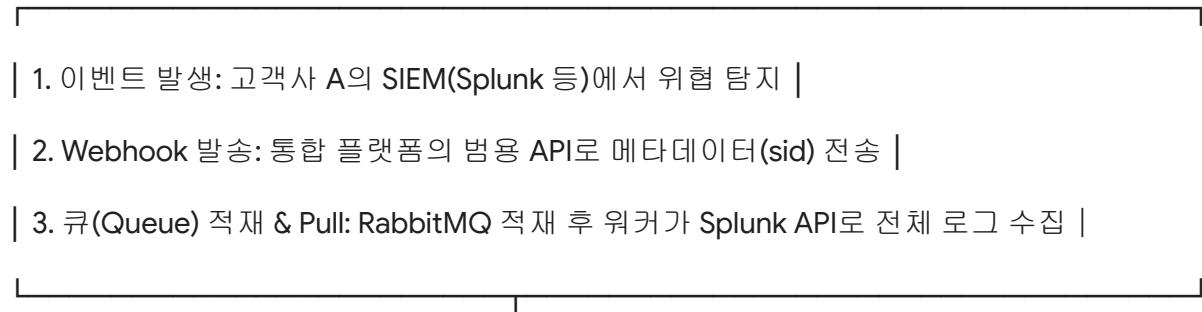
1. 좌측 패널 (목록 & 필터): 웹소켓을 통해 새로고침 없이 티켓이 실시간으로 흘러들어옵니다. 긴급도에 따라 색상이 구분되며, 남은 처리 시간(SLA)이 카운트다운 됩니다.

2. 중앙 패널 (분석 워크스페이스): 선택한 티켓의 상세 정보가 표시됩니다. 최상단에는 ****AI 요약 브리핑****이 하이라이트 되며, 하단에는 정규화된 데이터 테이블과 함께 필요 시 원본 JSON을 펼쳐볼 수 있는 코드 뷰어가 제공됩니다.
3. 우측 패널 (액션 & 플레이북): 화면 이동 없이 즉각적인 조치를 취하는 공간입니다. '방화벽 IP 차단', '고객사 이메일 발송' 등의 원클릭 버튼이 위치하며, 고객사별 템플릿(Jinja2)이 적용된 이메일 초안을 여기서 바로 수정하고 발송할 수 있습니다.

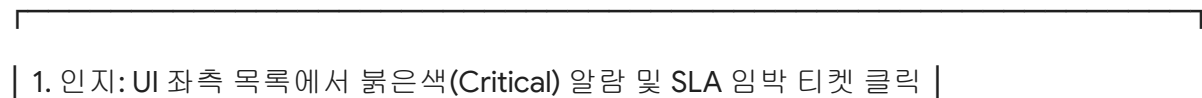
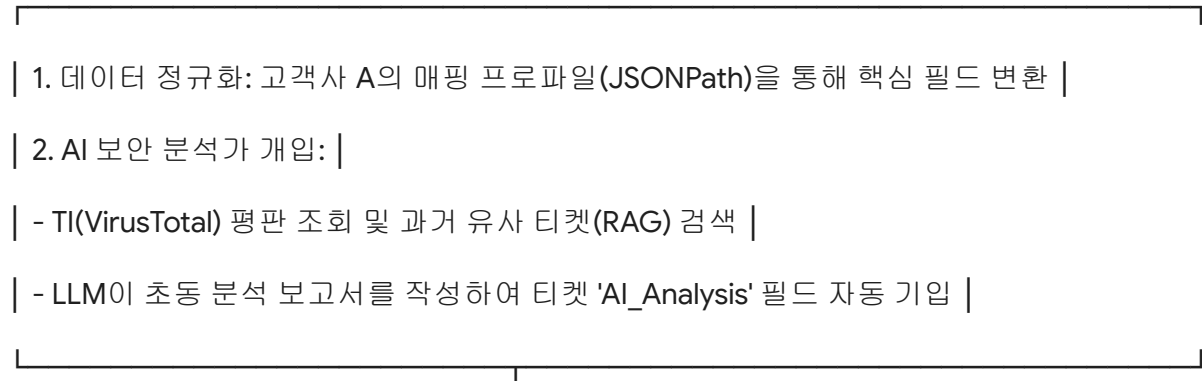
제6장. 엔드투엔드(End-to-End) 운영 프로세스 시나리오

이벤트 발생부터 고객사 알림까지, 실제 분석가가 경험하게 될 풀 프로세스 시각화입니다.

[Phase 1: 감지 및 무종단 수집 (Ingestion)]



[Phase 2: 동적 매핑 및 AI 초동 분석 (Processing)]



| 2. 상태 변경: 티켓 상태를 [New] → [Analyzing(분석 중)]으로 즉시 변경 |

| 3. 검토: 중앙 패널에서 AI 분석 결과와 원본 로그 대조 확인 |

| 4. 조치: 우측 패널에서 'IP 방화벽 차단' 또는 '계정 잠금' 액션 실행 |



| 1. 종결 처리: 근본 원인(Root_Cause) 기입 후 상태를로 변경 |

| 2. 리포트 렌더링: 시스템이 티켓 데이터를 고객사 A의 HTML 템플릿에 자동 삽입 |

| 3. 메일 발송: 설정된 담당자 메일 주소로 분석 내역 및 권고 사항 자동 발송 |

| 4. 지식 자산화: 해당 티켓의 처리 결과가 벡터 DB에 동기화되어 향후 AI의 학습 활용 |

제7장. 결론 및 바이브 코딩(Vibe Coding) 구현 전략

본 플랫폼은 단순한 버그 트래커인 Jira를 넘어서는, 철저히 보안 관제(SOC) 워크플로우에 맞춰진 특수 목적의 운영 체제입니다.

개발 지식이 깊지 않은 보안 담당자라도, Cursor나 Lovable과 같은 최신 AI 코딩 어시스턴트를 활용하는 ****바이브 코딩****을 통해 충분히 구현이 가능합니다.

- **UI 구현:** Lovable에 "3-Pane 레이아웃의 다크모드 보안 대시보드"를 프롬프트로 입력하여 React 기반 프론트엔드를 신속히 생성합니다.
- **백엔드/DB 연동:** Cursor IDE를 통해 "Supabase 연동을 위한 RLS 정책 생성" 및 "FastAPI와 RabbitMQ를 이용한 비동기 웹훅 수신기 코드"를 자연어로 요청하여 로직을 완성합니다.

이러한 접근은 상용 SOAR나 Jira 도입에 드는 막대한 라이선스 비용을 절감하는 동시에, 조직의 입맛에 100% 맞는 유연하고 강력한 플랫폼을 소유하게 되는 강력한 경쟁력이 될 것입니다.

참고 자료

1. Responsive design - Core concepts - Tailwind CSS, 2월 18, 2026에 액세스,
<https://tailwindcss.com/docs/responsive-design>